PROGRAMACIÓN SEGURA

Plan de Seguridad

SeguriTech - Desarrollo del Portal de Gestión de Incidentes de Ciberseguridad

Abraham Núñez Sánchez

CONTEXTO DEL PROYECTO

SeguriTech



Descripción del proyecto

El proyecto es un portal web para SeguriTech donde los clientes de SeguriTech reportan y dan seguimiento a incidentes de ciberseguridad propios, por ejemplo, si un cliente sufre un ataque de phishing o detecta actividad sospechosa en su red, entra al portal, llena un formulario con los detalles, y el equipo de SeguriTech le da seguimiento hasta resolverlo.

Por eso el sistema maneja datos sensibles: credenciales de acceso, reportes técnicos de vulnerabilidades, y datos de contacto de los clientes.

CONTEXTO DEL PROYECTO

SeguriTech



Clientes en primera línea

SeguriTech desarrollará un portal web donde los clientes reportan y dan seguimiento a incidentes de ciberseguridad propios.



Datos de alto valor

El sistema procesará credenciales, reportes de vulnerabilidades y datos de contacto: información altamente atractiva para atacantes.



Seguridad desde el diseño

El plan de seguridad se define antes de escribir la primera línea de código, no como una revisión de última hora.

ESTRUCTURA DEL PLAN

Ocho fases de un plan de seguridad completo



1. Sentar bases



2. Establecer equipos



3. Postura base



4. Amenazas y riesgos



5. Priorización



6. Creación de hitos



7. Simulacros



8. Mejora continua

FASE 1

Sentar bases

Define qué se va a hacer, cómo se va a hacer y las reglas que nadie rompe.

- ✓ Alcance del proyecto: autenticación, gestión de reportes y almacenamiento de evidencia digital.
- ✓ Regla obligatoria de equipo: ningún código llega a la rama principal sin revisión de seguridad.
- ✓ Estándares mínimos desde el día uno: HTTPS en todas las rutas, hashing de contraseñas y validación de entradas.

FASE 2

Establecer equipos



Líder de seguridad

Revisa arquitectura y código antes de cada release.



Responsable de datos

Cifrado, respaldos y control de acceso a la base de datos.



Contacto con cliente

Recibe reportes de vulnerabilidades externos y nuevos requisitos.



Encargado de incidentes

Coordina la respuesta cuando algo falla en producción.

FASE 3

Establecer una postura base de seguridad



Autenticación reforzada

MFA obligatorio para cuentas administrativas y de soporte.



Contraseñas robustas

Hash + salt; longitud mínima de 12 caracteres con caracteres especiales.



Cifrado en tránsito y reposo

TLS más reciente en toda comunicación; AES-256 para evidencia almacenada.



Mínimo privilegio

Cada rol de base de datos accede solo a lo estrictamente necesario.

FASE 4

Evaluación de amenazas y riesgos

Amenaza identificada	Probabilidad	Impacto	Prioridad
Inyección SQL en formulario de reportes	Alta	Alto	Crítica
Autenticación rota (sesiones sin expirar)	Media	Alto	Alta
Exposición de datos vía API sin control de acceso	Media	Alto	Alta
Phishing dirigido al equipo de soporte	Baja	Medio	Media

FASE 5

Priorización

Frecuente	100%	1	2	3	4	5
	90%	0,9	1,8	2,7	3,6	4,5
Probable	80%	0,8	1,6	2,4	3,2	4
	70%	0,7	1,4	2,1	2,8	3,5
Ocasional	60%	0,6	1,2	1,8	**2,4**	3
	50%	0,5	1	1,5	2	2,5
Posible	40%	0,4	0,8	1,2	**1,6**	2
	30%	0,3	0,6	0,9	1,2	1,5
Improbable	20%	0,2	0,4	0,6	0,8	1
	10%	0,1	0,2	**0,3**	0,4	0,5
		1 Insignificante	2 Menor	3 Moderado	4 Mayor	5 Catastrófico

Criterio de priorización

Con tiempo limitado, se atiende primero la falla que combine mayor impacto potencial con mayor facilidad de explotación, especialmente si expone datos de clientes o es accesible desde fuera de la red.

FASE 6

Creación de hitos

Fechas límite y metas claras para medir el avance de la seguridad.



FASE 7

Realizar simulacros y ejercicios basados en casos



Pentesting interno

Pruebas de penetración antes de cada liberación, enfocadas en inyección y autenticación.



Phishing simulado

Campaña controlada dirigida al equipo de soporte para medir capacidad de detección.



Simulacro de incidente

Ejercicio de respuesta con datos de prueba: detección, contención y comunicación al cliente.

FASE 8

Expansión y mejora continua de los equipos de seguridad

Revisión continua

El plan de seguridad se evalúa cada temporada contra nuevas amenazas.

Parches y dependencias

Actualización constante de librerías y componentes con vulnerabilidades conocidas.

Capacitación continua

El equipo se forma de manera constante en nuevas técnicas de ataque.

REFLEXIÓN

¿Una sola regla obligatoria para todo el equipo?



Ningún código debe integrarse al proyecto sin haber sido revisado y validado desde el punto de vista de seguridad.

¿Por qué?

Permite detectar vulnerabilidades antes de que lleguen al sistema en producción. La mayoría de las reglas de seguridad protegen contra un tipo específico de amenaza. La revisión de código funciona como una red de seguridad que atrapa todo lo demás. Aunque un desarrollador olvide limpiar un campo, use una librería con una vulnerabilidad conocida, o exponga una llave por accidente, la revisión da una segunda oportunidad de detectarlo antes de que el error se vuelva un incidente real.

REFLEXIÓN

Múltiples fallas, tiempo limitado: ¿qué se atiende primero?



Se prioriza por impacto potencial combinado con facilidad de explotación.

1

¿Qué tan grave sería?

Fallas que exponen datos de clientes o credenciales van primero, sin excepción.

2

¿Qué tan fácil es explotarla?

Una vulnerabilidad simple de ejecutar sube de prioridad de inmediato.

3

¿Está expuesta al exterior?

Lo que es accesible desde fuera de la red pesa más que lo interno.